

Corrigé TP : Analyse

1. Synthèse de la Surface d'Attaque

Voici le tableau complété avec les observations typiques relevées sur les deux machines "sorties d'installation" avant durcissement :

Composant analysé	Machine Linux	Machine Windows Server	Risque potentiel identifié
Comptes & Privilèges	• Accès direct root actif. • Utilisateur de stage membre complet de sudo sans restriction de commandes. • Présence possible de faux comptes de service avec un shell /bin/bash.	• Compte Administrateur local par défaut non renommé. • Compte Invité (Guest) parfois mal désactivé. • Mots de passe sans politique stricte de complexité ou de verrouillage.	Élévation de privilèges directe, attaques par force brute (<i>credential stuffing</i>) facilitées par des noms de comptes prévisibles.
Ports exposés (0.0.0.0)	• Port 22 (SSH) ouvert à tous. • Port 631 (CUPS / impression) en écoute. • Port 111 (rpcbind) actif.	• Port 3389 (RDP) exposé à tout le sous-réseau. • Ports 445 (SMB) et 135 (RPC) ouverts. • Port 5985 (WinRM HTTP) actif.	Écoute réseau globale sans restriction d'IP source ; vecteurs directs d'attaques à distance (<i>Man-in-the-Middle</i> , exploits RDP/SMB).
Services inutiles actifs	• Serveur d'impression (cups.service).	• Spouleur d'impression (<i>Print Spooler</i> - vulnérabilités type	Élargissement inutile de la surface d'attaque : failles potentielles

	• Résolution mDNS (avahi-daemon). • Agent de messagerie local (postfix ou exim4).	PrintNightmare). • Registre à distance (<i>Remote Registry</i>). • Télémétrie et services multimédia.	exploitables sur des services sans utilité serveur métier.
Permissions / Partages	• Droits trop permissifs sur certains dossiers temporaires (/tmp sans options noexec). • Binaires avec bit SUID actif (ex: passwd, su, parfois détournables).	• Partages administratifs cachés actifs (C\$, ADMIN\$, IPC\$). • Dossiers de test partagés accessibles à "Tout le monde" (<i>Everyone</i>).	Mouvements latéraux sur le réseau local, fuite de données et élévation de privilèges via GTFOBins sous Linux.
Posture Pare-feu	• ufw ou nftables inactif (Status: inactive). • Chaînes par défaut à ACCEPT sans filtrage local.	• Profil Privé ou Public désactivé par commodité lors des tests. • Règles entrantes trop permissives (tous flux autorisés sur le subnet).	Aucune défense en profondeur : si un attaquant accède au réseau interne, aucun filtrage local ne bloque ses scans ou attaques.

2. Réponses clés

Linux

- **Comptes interactifs** : Seuls les comptes réels (ex: stagiaire ou admin) et root doivent disposer d'un shell. Les comptes comme daemon, games, www-data doivent avoir /usr/sbin/nologin.
- **Ports et services** : Faire remarquer la différence fondamentale entre 127.0.0.1:port (accessible uniquement en local par le serveur) et 0.0.0.0:port / :::port (exposé à tout le réseau d'entreprise).
- **Fichiers critiques** :
 - /etc/shadow doit être strictement en 640 ou 400 appartenant à root:shadow.
 - Tout binaire SUID atypique (ex: find, vim, python) doit être immédiatement signalé comme une anomalie critique.

Windows Server

- **Compte Administrateur** : Il doit être renommé et son mot de passe durci, car le RID 500 est ciblé en priorité par les scripts automatiques.
- **RDP** : Expliquer qu'un port 3389 ouvert sur toutes les interfaces sans NLA (*Network Level Authentication*) expose la machine aux attaques de pré-authentification (comme *BlueKeep*).
- **Partages** : Rappeler que les partages administratifs (C\$, ADMIN\$) sont natifs, mais qu'ils doivent être surveillés et isolés via le pare-feu local pour empêcher les outils d'administration malveillants (PsExec).